

Daily Vulnerability Report - 2026-09-11

Window (UTC): 2026-09-11T00:00 to 2026-09-12T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 09:55:55 UTC

Total	New	Updated	KEV	Critical	High	Medium	Unscored	Watchlist	Packages
1100	725	375	10	142	443	286	204	77	41

P1 - Act now (KEV / high EPSS)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86060 Newly scored	9.8	CRIT	Yes	0.011	mikrotik:routeros	RouterOS contains an argument-handling flaw in the SSH login path involving usernames that begin with a prohibited character, allowing for the trusted RouterOS policy mask to be changed, leading to privilege escalation. Exploitation requires an unauthenticated SSH session to reach the RouterOS login helper.This issue was fixed in versions: 6.49.21 (Long-term), 7.23.4 (Long-term) and 7.24.2 (Stable)
CVE-2026-58704 Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-67277 Newly scored	8.2	HIGH	Yes	0.009	mikrotik:routeros	RouterOS accepts a "related" btest connection before the corresponding primary session has completed authentication. An unauthenticated client can use this state to start an IPv4 UDP test. With "random-data=false", the sender transmits an uninitialized tail from a kernel packet buffer. A separate unchecked, inverted packet-size interval causes unsigned integer underflow, anomalously large fragmented output, and ca...
CVE-2026-42016 Added to KEV			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-42018 Added to KEV			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-76460 Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461 Added to KEV			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-84869 Added to KEV			Yes	0.007	connectwise:screenconnect	ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to transfer and execute files through an active remote session without authorization or host confirmation.
CVE-2026-85706 Added to KEV			Yes	0.12	gitlab:community edition and enterprise edition	GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-87886 Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-14560 New	10.0	CRIT		0.004		The teddy-bear-customize-addon WordPress plugin through 1.0.5 does not properly validate uploaded files, relying on a client-supplied content type and preserving the original filename, allowing unauthenticated attackers to upload arbitrary PHP files and execute code on the server.
CVE-2026-80462 New	10.0	CRIT		0.003		A vulnerability in the Chef Automate API gateway and identity validation path may allow an unauthenticated actor to gain elevated access to protected Chef Automate functionality under specific conditions.
CVE-2026-82004 Newly scored	10.0	CRIT		0.014	adobe:campaign	Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-87985 New	10.0	CRIT		0.004		An arbitrary code execution vulnerability in Mistral Vibe allows an attacker to bypass command permission checks using ANSI-C quoted arguments. These arguments are not properly inspected, enabling a crafted allowlisted command to execute arbitrary code on the user's system without approval.
CVE-2026-87986 New	10.0	CRIT		0.004		An arbitrary code execution vulnerability in Mistral Vibe allows an attacker to bypass command permission checks using shell constructs it's parser cannot interpret. Unparsed portions are omitted from inspection, enabling embedded commands to execute on the user's system without approval.
CVE-2026-87987 New	10.0	CRIT		0.003		An arbitrary code execution vulnerability in Mistral Vibe allows an attacker to bypass command permission checks using environment variable assignments preceding allowlisted commands. These assignments are excluded from inspection, enabling attacker-controlled environment variables to cause arbitrary code execution without user approval.
CVE-2026-87988 New	10.0	CRIT		0.003		An arbitrary file access vulnerability in Mistral Vibe allows an attacker to bypass workspace restrictions through commands classified as unconditionally allowed. Missing path validation for these commands enables access to files outside the active workspace without user approval.
CVE-2026-19232 Newly scored	9.9	CRIT		0.006	adobe:experience_manager	Adobe Experience Manager is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user, potentially gaining elevated access or control over the victim's account or session. A low-privileged attacker could exploit this vulnerability to gain elevated access or control over the victim's account or session. Exploitation of this issue does not r...
CVE-2026-65646 Newly scored	9.9	CRIT		0.004		Improper neutralization of special elements in in Plesk's DNS zone management functionality allows remote authenticated users to disclose arbitrary local files and escalate privileges.
CVE-2026-66897 Newly scored	9.9	CRIT		0.007	canonical:lxd	A path traversal vulnerability in LXD's instance template processing allows an attacker with container edit permissions, or any user launching a crafted image, to overwrite arbitrary files on the host system as root. When processing target template paths specified in metadata.yaml, LXD validates the path against a confined os.Root directory handle but subsequently opens and creates the file using os.Create with an...
CVE-2026-14559 New	9.8	CRIT		0.003		The teddy-bear-customize-addon WordPress plugin through 1.0.5 does not verify a user's password before authenticating them, allowing unauthenticated attackers to log in as any registered user, including administrators, by supplying only that user's email address.
CVE-2026-14563 New	9.8	CRIT		0.003		The advanced-customized-prompts WordPress plugin through 1.0.1 does not verify the password before issuing an authenticated session for a supplied email address in an unauthenticated action, allowing unauthenticated attackers to log in as any registered user, including administrators, or to create arbitrary new accounts.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-21095 Newly scored	9.8	CRIT		0.005	samsung:android	Heap-based buffer overflow in DNG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-21096 Newly scored	9.8	CRIT		0.005	samsung:android	Heap-based buffer overflow in JPEG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-52630 New	9.8	CRIT		0.005		SQL Injection vulnerability in Woltlab WCF v.6.2.4 and before allows a remote attacker to updateUserOptions in UserEditor.class.php and the update action in UserAction.class.php
CVE-2026-53952 New	9.8	CRIT		0.003		GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. A logic flaw in GetSimple CMS (v3.4.0a and below) and GetSimpleCMS-CE (v3.3.22 and below) allows unauthenticated attackers to create a new administrator account. The application features an automated security control designed to delete the sensitive `admin/setup.php` file post-installation. However, this ...
CVE-2026-62103 New	9.8	CRIT		0.003		Unauthenticated PHP Object Injection in Everest Forms <= 3.6.0 versions.
CVE-2026-62105 New	9.8	CRIT		0.003		Unauthenticated PHP Object Injection in ThemeREX Addons < 2.45.0 versions.
CVE-2026-63073 Newly scored	9.8	CRIT		0.009	openssl:openssl	Issue summary: OpenSSL CMP response validation passed an unexpected response sender distinguished name directly as the format string to `ERR_raise_data()`. Impact summary: A malicious or intercepted CMP endpoint can crash a CMP client that enforces an expected sender or uses a pinned server certificate whose subject becomes the default expected sender. CWE: CWE-134 (Use of Externally-Controlled Format String) D...
CVE-2026-69431 Newly scored	9.8	CRIT		0.009		Heap-based buffer overflow in Telnet Client allows an unauthorized attacker to execute code over a network.
CVE-2026-71644 New	9.8	CRIT		0.004		An issue in Robotics-STAR-Lab (SYSU STAR Group) RACER Tested affected version: commit abcdef1234567890 allows an attacker to cause unsafe trajectory planning and potential UAV collisions via a missing default case in the FSM that stops publishing swarm trajectories when the drone enters IDLE
CVE-2026-77089 Newly scored	9.8	CRIT		0.003	commvault:commvault	Command Center API contained an authentication bypass issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update Command Center.
CVE-2026-77092 Newly scored	9.8	CRIT		0.002	commvault:commvault	Content Extractor contained a deserialization of untrusted data issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update Content Extractor.
CVE-2026-77098 Newly scored	9.8	CRIT		0.003	commvault:commvault	Private Metrics Server contained an SQL injection condition affecting database operations. Software customers upgrade to resolved maintenance release. Update Private Metrics Server.
CVE-2026-78445 Newly scored	9.8	CRIT		0.009	microsoft:windows_server_2012, microsoft:windows_server_2016, microsoft:windows_server_2019, microsoft:windows_server_20	Use after free in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-79395 New	9.8	CRIT		0.004		An improper authentication vulnerability in the WS-Security (wsse:UsernameToken) verification routine within the Sofia IPC daemon in Xiongmai IP Camera XM530 firmware HMT.CM2005-v220608.1837 and earlier allows remote attackers to bypass authentication and execute privileged ONVIF actions (including PTZ control, stream URL retrieval, and system reboot) via a crafted SOAP request supplying the admin username with an...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79396 New	9.8	CRIT		0.004		Use of hardcoded default credentials in Xiongmai IP Camera XM530 firmware HMT.CM2005-v220608.1837 and earlier stores static account credentials in unencrypted plaintext within bin/config.xml and compiled into the Sofia executable, allowing remote attackers to gain full administrative control over the camera.
CVE-2026-79689 Newly scored	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-79941 Newly scored	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-80172 Newly scored	9.8	CRIT		0.003	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Insufficient Verification of Data Authenticity vulnerability. An unauthenticated attacker with remote access could exploit this, leading to unauthorized access. This vulnerability is considered critical as an unauthenticated attacker can repeatedly reuse a captured request to generate ADMIN ac...
CVE-2026-80926 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix use-after-free in oplock break notification smb2_oplock_break_noti() reads opinfo->conn without any lock and dereferences it after two allocations which may sleep. When the durable handle owning the oplock is disconnected, session_fd_check() clears opinfo->conn and drops its conn reference under ci->m_lock, and the last ksmbd_conn_pu...
CVE-2026-80976 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: seg6: reset IP6CB after IPv6 decapsulation decap_and_validate() pulls the outer SRv6 headers and makes the inner packet the skb network header. The IPv6 control block still contains values collected while parsing the outer packet, including nhoff and extension-header flags. End.DX6 and End.DT6 route the inner IPv6 packet directly to the IPv6 in...
CVE-2026-80980 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: net/smc: stop killed, freed and out_of_sync sharing a byte The three connection state flags are single-bit bitfields, so they occupy one byte of struct smc_connection and every store to one is a read-modify-write of the other two: u8 killed : 1; u8 freed : 1; u8 out_of_sync : 1; They are not written under a common lock. smc_cdc_...
CVE-2026-80981 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: net/smc: fix use-after-free of the LLC qentry in smc_llc_srv_add_link() smc_llc_srv_add_link() keeps add_llc pointing into the queue entry: add_llc = &qentry->msg.add_link; smc_llc.c:1482 ... smc_llc_save_add_link_info(link_new, add_llc); smc_llc.c:1494 smc_llc_flow_qentry_del(&lgr->llc_flow_lcl); smc_llc.c:1495 ... u8 *llc_msg =...
CVE-2026-80986 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: net/smc: bound the peer rkey counts in SMC-Rv2 LLC messages On a link whose device has max_rcv_sge == 1 there is no shared v2 receive buffer, and smc_llc_save_add_link_rkeys() takes the v2 extension from 44 bytes past the start of the queue entry's inline message: ext = (struct smc_llc_msg_add_link_v2_ext *)(&llc_msg + SMC_WR_TX_SIZE); The e...
CVE-2026-81002 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: xdp: fix zero-copy frame layout xdp_convert_zc_to_xdp_frame() clones an XSK packet into an order-0 page and advertises PAGE_SIZE as its frame size. It allows the copied frame to occupy the page tail needed by skb_shared_info and records zero headroom even when metadata separates the frame header from packet data. An AF_XDP zero-copy packet redi...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82617 New	9.8	CRIT		0.003	apache:opennlp	The two built-in name-finder patterns exposed by <code>opennlp.tools.namefind.RegexNameFinderFactory - DEFAULT_REGEX_NAME_FINDER.EMAIL</code> and <code>DEFAULT_REGEX_NAME_FINDER.URL</code> - contain ambiguous nested quantifiers. An application that obtains these finders through <code>RegexNameFinderFactory.getDefaultRegexNameFinders(...)</code> and then applies them to untrusted text through <code>RegexNameFinder.find(String[])</code> or <code>RegexNameFinder.find(String...</code>
CVE-2026-84390 New	9.8	CRIT		0.005		A inclusion of sensitive information in source code vulnerability in Fortinet FortiMonitorOnSight 7.2.4 through 7.2.7, FortiMonitorOnSight 7.2.0 through 7.2.2 may allow attacker to improper access control via <insert attack vector here>
CVE-2026-86793 New	9.8	CRIT		0.004		SGLang allows unauthenticated pickle deserialization through <code>/update_weights_from_tensor</code> when no auth keys are configured, and the <code>SafeUnpickler</code> policy can be bypassed because <code>builtins.import</code> and <code>builtins.getattr</code> are resolvable, enabling code execution via pickle <code>REDUCE</code> .
CVE-2026-8778 New	9.8	CRIT		0.006		The MIPL Grouped Checkout Fields for WooCommerce – Customize & Organize Checkout Fields. plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the <code>`mipl_wc_upload_file`</code> function in all versions up to, and including, 1.2.1. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution po...
CVE-2026-89478 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: <code>sctp</code> : drop a chunk if its transport was removed <code>sctp_rcv()</code> resolves the transport once per packet and leaves it in <code>chunk->transport</code> . The lookup reference, or the one <code>sctp_add_backlog()</code> takes if the socket is owned by userspace, keeps it around until the chunk has been processed. An authenticated <code>ASCONF DEL-IP</code> can remove it in the meantime. <code>sctp...</code>
CVE-2026-89479 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: <code>sctp</code> : stop processing a packet once its association is deleted <code>sctp_endpoint_bh_rcv()</code> looks the association up only when <code>chunk->asoc</code> is <code>NULL</code> , and caches the result in <code>chunk->asoc</code> and <code>chunk->transport</code> without taking a reference. A packet that matches no association is handed to the endpoint, so a peer can bundle <code>COOKIE ECHO</code> , <code>SHUTDOWN</code> and <code>SHUTDOWN...</code>
CVE-2026-89482 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: <code>nvme-tcp</code> : do not accept <code>C2HData</code> based on <code>blk_rq_payload_bytes()</code> alone Commit 25e5cb780e62 (" <code>nvme-tcp</code> : fix possible crash in <code>write_zeroes</code> processing") established that <code>blk_rq_payload_bytes()</code> must not be read without first checking <code>blk_rq_nr_phys_segments()</code> , and recorded the result in <code>nvme_tcp_setup_cmd_pdu()</code> as <code>req->data_len</code> . The receive side was...
CVE-2026-89485 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: <code>lockd</code> : pin next file across <code>nlm_inspect_file</code> <code>lock-drop</code> <code>nlm_traverse_files()</code> pins the current file with <code>f_count++</code> across a <code>mutex_unlock</code> for <code>nlm_inspect_file()</code> , but nothing pins the saved next pointer. A concurrent <code>nlm_release_file()</code> can <code>kfree</code> the next file during the unlock window, and the iterator dereferences freed memory on the next loop step...
CVE-2026-89492 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: <code>ocfs2</code> : validate directory-index entry counts when reading metadata <code>ocfs2_validate_dx_leaf()</code> and <code>ocfs2_validate_dx_root()</code> check the ECC and signature of an indexed-directory block before it reaches higher-level callers, but neither validator bounds the <code>ocfs2_dx_entry_list</code> counts against the capacity of the block that holds them. <code>ocfs2_dx_dir_sea...</code>
CVE-2026-89494 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: <code>ocfs2</code> : validate lengths in <code>dlm_mig_lockres_handler</code> A node receiving a <code>DLM_MIG_LOCKRES</code> message trusts several fields of the peer-supplied <code>dlm_migratable_lockres</code> without validation. <code>num_locks</code> and <code>lockname_len</code> are bounded only on the sending side, and the message is never checked to actually carry <code>num_locks</code> <code>migratable_lock</code> entries. As a result <code>dl...</code>

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89495 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: ocfs2: bound namelen in dlm_migrate_request_handler Patch series "ocfs2/dlm: bound peer-controlled lengths in the o2dlm". The o2dlm receive handlers trust u8 length and count fields from the wire without bounding them, so a node in a DLM domain can corrupt or panic any other node with a malformed message. Three defects: - dlm_migrate_reques...
CVE-2026-89526 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Validate Read chunk positions before reconstruction The RPC/RDMA Read chunk position field is supplied by the remote client and stored verbatim in the parsed chunk list. xdr_count_read_segments() checks only 4-byte alignment; it never compares the position against the received inline body length. In the single-chunk path, svc_rdma_read...
CVE-2026-89530 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reject inline replies that overflow the pull-up buffer An RPC-over-RDMA client can request a reply, such as an NFS READ payload, without providing a Write list or a Reply chunk to carry it. When such a reply needs more scatter/gather entries than the device's Send Queue supports, svc_rdma_pull_up_needed() selects pull-up and svc_rdma_pu...
CVE-2026-89533 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix offset arithmetic in read_chunk_range svc_rdma_read_chunk_range() walks a Read chunk's segment list to build a sub-range starting at byte offset and spanning length bytes for a Position-Zero or Call chunk. Two arithmetic defects in the per-segment loop produce wrong DMA lengths and a u32 underflow: pcl_for_each_segment(segment,...
CVE-2026-89536 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: wait for in-flight client TLS handshake callback xs_tls_handshake_sync() gives xs_tls_handshake_done() a reference to the lower transport before submitting the handshake request. On timeout or signal, the synchronous waiter drops that reference after calling tls_handshake_cancel(). handshake_req_cancel() returns false when handshake_com...
CVE-2026-89538 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Reject krb5 v2 wrap tokens with oversized ec field gss_krb5_unwrap_v2() sets buf->len to a logical length, which can be much smaller than head[0].iov_len (the allocated receive-page capacity). It then calls xdr_buf_trim() with a trim length derived from the 16-bit "extra count" (ec) field in the Kerberos v2 token header. The ec field i...
CVE-2026-89541 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_unwrap_resp_priv length checks gss_unwrap_resp_priv() validates the RPCSEC_GSS opaque length with offset = (u8 *) (p) - (u8 *) head->iov_base; if (offset + opaque_len > rcv_buf->len) goto unwrap_failed; maj_stat = gss_unwrap(ctx->gc_gss_ctx, offset, offset + opaque_len, rcv_buf)...
CVE-2026-89542 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_krb5_unwrap_v2 against short tokens gss_krb5_unwrap_v2() reads the EC and RRC header fields at ptr+4 and ptr+6 before validating that the token is at least GSS_KRB5_TOK_HDR_LEN (16) bytes long, and its rotate_left() helper passes buf->len - base to xdr_buf_subsegment() without verifying that base <= buf->len. When a caller han...
CVE-2026-89546 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: close backchannel before destroying callback service A backchannel receive can complete a request while the NFS callback service is being torn down. xprt_complete_bc_request() removes the request from bc_pa_list, drops bc_alloc_count, marks the request in use, and then asks xprt_enqueue_bc_request() to hand it to the callback service. ...
CVE-2026-89550 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: svcauth_gss: enforce krb5 token minimum length svcauth_gss_unwrap_priv() validates only an upper bound on the wire-supplied opaque length before handing the buffer to gss_unwrap(): if (len > xdr_stream_remaining(xdr)) goto unwrap_failed; offset = xdr_stream_pos(xdr); ... maj_stat = gss_unwrap(ctx, offset, off...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89551 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: xdr_buf_trim: clamp buf->len to avoid underflow xdr_buf_trim() trims `len` bytes from the tail of an xdr_buf by walking the tail, pages, and head iovecs. Each per-section step uses min_t() so it never removes more bytes than that section holds, but the final accounting at the fix_len label subtracts the total bytes actually consumed fro...
CVE-2026-89555 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: mpls: reload header after pskb_may_pull() mpls_select_multipath() calls mpls_multipath_hash() to choose a nexthop when an MPLS route has multiple nexthops. While walking the MPLS label stack, the hash routine caches hdr for the current label. After finding the bottom-of-stack label, it calls pskb_may_pull() before reading the inner IP header. ...
CVE-2026-89558 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: md/raid10: fix still_degraded being inverted in raid10_sync_request() Commit fe6a19d40ceb ("md/md-bitmap: merge md_bitmap_start_sync() into bitmap_operations") converted still_degraded from int to bool, but inverted the assignment in the loop that checks whether the array will still be degraded after the current device is recovered: "still_degra...
CVE-2026-89610 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ntfs: verify run length exceeding volume boundary The mapping pairs decoder validates that the starting LCN is within the volume but does not check if the run extends beyond the volume boundary. A malformed NTFS image with a crafted mapping pairs array could cause the kernel to access memory beyond the volume boundary, potentially leading to me...
CVE-2026-89611 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: ntfs: validate non-resident attribute offsets ntfs_attr_update_meta() shifts the attribute name when converting between non-sparse and sparse attributes. Converting to sparse also adds the compressed_size field before the name and mapping pairs, requiring eight additional bytes in the attribute record. However, the validator does not check that...
CVE-2026-89612 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ntfs: reject invalid MFT LCNs from boot sector The NTFS boot sector stores the MFT and MFTMirr locations as unsigned 64-bit LCNs, but parse_ntfs_boot_sector() decoded them into an s64. A crafted high-bit value could therefore become negative and pass the existing upper-bound check. The invalid value then propagated into the MFT zone allocator a...
CVE-2026-89613 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ntfs: reject invalid empty mapping pairs Reject an attribute with empty mapping pairs if it has inconsistent highest VCN and size.
CVE-2026-89614 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: ntfs: bound the free-cluster bitmap scan to the volume vol->lc_n_empty_bits_per_page is sized from vol->nr_clusters at mount, but ntfs_cluster_alloc() bounds its scan of that array by the size of \$Bitmap. Those are independent on-disk quantities and the mount-time check only rejects a \$Bitmap that is too small, so an image whose \$Bitmap covers mo...
CVE-2026-89633 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: smb: client: fix OOB read/write from unvalidated DataOffset in coalesce_t2() coalesce_t2() computes data pointers directly from server-supplied DataOffset fields with no validation against buffer bounds: data_area_of_tgt = (char *)&pSMBt->hdr.Protocol + get_unaligned_le16(&pSMBt->t2_rsp.DataOffset); data_area_of_src = (...
CVE-2026-89635 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ksmbd: only rebind the reopened file's own oplock on durable reconnect ksmbd_reopen_durable_fd() walks the inode's m_op_list and rebinds every detached oplock to the reconnecting session: list_for_each_entry_rcu(op, &ci->m_op_list, op_entry, lockdep_is_held(&ci->m_lock)) { if (op->conn) continue; op->conn = ksmbd_conn_get(fp->conn);...
CVE-2026-89636 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: smb: client: clear ce->tgthint in free_tgts() When free_tgts() frees all structures in ce->tlist, ce->tgthint is left pointing to one of the freed cache_dfs_tgt structures. If ce->tgthint is not reset before it is used later, it results in a use-after-free. Set ce->tgthint to NULL in free_tgts() after the elements are freed to reflect that no ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89637 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: smb: client: fix UAF and buffer leak in cifs_check_trans2() for malformed secondary T2 When a valid primary TRANSACT2 response has been received (mid->resp_buf set, mid->multiRsp true) and a subsequent secondary response causes cifs_check_trans2() to return false -- either because the SMB header is invalid (malformed != 0) or because check2ndT2(...
CVE-2026-89643 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: audit: avoid dropping live tree ref on fsnotify rule autoremove audit_del_rule() is used for both netlink deletion templates and internal fsnotify autoremove. The former passes a parsed template which owns a temporary tree reference; the latter passes the installed entry itself. The unconditional audit_put_tree() at the end of audit_del_rule()...
CVE-2026-89651 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ceph: bound MDSCapAuth path and fs_name decode in handle_session() handle_session() decodes the MDSCapAuth records carried by a CEPH_SESSION_OPEN message (msg_version >= 6). For each record the match.path and match.fs_name byte strings are read by first decoding a 32-bit length and then copying that many bytes with the bare ceph_decode_copy(). U...
CVE-2026-89652 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: bound copied dentry name length in NFS export get_name ceph_get_name() copies the MDS-supplied name into the caller's NAME_MAX-sized buffer with memcpy(name, rinfo->dname, rinfo->dname_len) and then writes name[rinfo->dname_len] = 0, without checking dname_len against NAME_MAX. A malicious or buggy MDS that returns a LOOKUPNAME reply with ...
CVE-2026-89653 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: reject export_targets ranks >= CEPH_MAX_MDS in mdsmmap decode MDSMap export_targets entries are monitor controlled. check_new_map() uses each entry as a bit number in a fixed stack bitmap, so a rank outside the protocol namespace can make set_bit() write past the end of the array. Reject ranks outside CEPH_MAX_MDS while decoding the map. D...
CVE-2026-89654 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: ceph: fix UAF in check_new_map() on session freed during unlock check_new_map() iterates mdsc->sessions[] and for each active session drops mdsc->mutex to perform per-session operations. The forced-close path (rank removed from map) correctly takes a reference on s via ceph_get_mds_session() before releasing mdsc->mutex, but three other paths d...
CVE-2026-89655 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: ceph: fix UAF in __kick_flushing_caps() on cf entry freed during unlock list_for_each_entry() iterates ci->i_cap_flush_list but drops i_ceph_lock to send cap messages. During the unlock window, handle_cap_flush_ack() can acquire i_ceph_lock, detach cf entries with tid <= flush_tid from the list, release i_ceph_lock, and free them via ceph_free_...
CVE-2026-89656 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: libceph: reject buckets with mismatched CRUSH ids crush_decode() stores bucket data by array slot, and the mapper later derives the per-bucket workspace index from the decoded bucket id. A malformed map can therefore make one bucket reuse another bucket's workspace by encoding an id different from -1 - slot. For uniform buckets, the second repl...
CVE-2026-89658 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: NFSv4.0 revoked-state cleanup nfs40_clean_admin_revoked() takes a stateid reference under clp->cl_lock, drops nn->client_lock, and calls nfsd4_drop_revoked_stid(), which dereferences the stateid's client through s->sc_client->cl_lock. The stateid reference does not pin the client, so a teardown racing ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89659 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during delegation revoke A delegation stateid holds only a bare pointer to its owning nfs4_client and does not keep it alive. The client survives its stateids only because __destroy_client() drains cl_delegations and cl_revoked before free_client() runs. nfs4_laundromat() breaks that invariant: it unhashes a...
CVE-2026-89660 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent client use-after-free during admin state revocation A stateid holds only a bare pointer to its nfs4_client; a stateid reference does not pin it. The client survives only because __destroy_client() drains its stateids before free_client() runs. nfsd4_revoke_states() drops nn->client_lock across revoke_one_stid(), which dereference...
CVE-2026-89662 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent lock owner use-after-free during client teardown __destroy_client() releases a client's open owners, but a lock owner whose only reference is a blocked lock (nbl) stays on cl_ownerstr_hashtbl. client_has_state() does not count a bare owner, so DESTROY_CLIENTID can reach __destroy_client() with such owners present. __destroy_clien...
CVE-2026-89669 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: nfsd: initialize copy-notify stateid before publishing it nfsd4_copy_notify() finished initializing the cpntf state after nfs4_alloc_init_cpntf_state() had already linked it into the s2s_cp_stateids IDR and the parent's sc_cp_list, with cs_count == 1 (the membership reference) and none held for the caller. A racing OFFLOAD_CANCEL (crafted cl_id ...
CVE-2026-89674 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix XDR length calculation in nfsd4_ff_encode_layoutget The XDR buffer size calculation in nfsd4_ff_encode_layoutget() has multiple errors that can result in either an out-of-bounds write or leaking uninitialized kernel memory to the client: - fh_len doesn't account for XDR padding on the file handle data - uid and gid lengths use "8 + ...
CVE-2026-89675 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix UAF in async copy cancel and shutdown An async copy could be freed or used after free while a teardown caller (OFFLOAD_CANCEL, nfsd4_shutdown_copy, nfsd4_cancel_copy_by_sb) raced the copy kthread: - find_async_copy() bumped copy->refcount but left the copy on clp->async_copies, so the reaper's cleanup_async_copy() could run ...
CVE-2026-89676 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix stale s2s_cp_stateids IDR entry for async COPY For an async COPY, nfsd4_copy() called nfs4_init_copy_state() before dup_copy_fields(), so the s2s_cp_stateids IDR was pointed at &u->copy->cp_stateid -- memory in the per-rqstp COMPOUND buffer that is reused by the next request. dup_copy_fields() copies only the value into async_copy, so ...
CVE-2026-89677 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix possible fh_compose of wrong dentry in nfsd4_create_file() dentry_create() can hypothetically provide a different dentry than the one passed in. This could happen, for example, if the exported filesystem is NFS, and the server returned to OPEN a filehandle which matched a directory that was already in the dcache. Clearly this would n...
CVE-2026-89681 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix layout fence worker double-reference race The workqueue core clears WORK_STRUCT_PENDING before the callback is invoked, so delayed_work_pending() in lm_breaker_timedout() can return false while the fence worker is already running. This lets the breaker take a duplicate sc_count reference and schedule a new worker that coalesces with th...
CVE-2026-89686 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix BUG_ON in nfsd4_alloc_layout_stateid on racing delegation revoke nfsd4_alloc_layout_stateid reads fp->fi_deleg_file without holding fi_lock when the parent stateid is a delegation. A concurrent delegation revoke via the laundromat can clear fi_deleg_file under fi_lock, causing nfsd_file_get() to return NULL and triggering the BUG_ON. ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89688 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: nfsd: drop the stateid, not the stateowner, on seqid_op replay retry In nfs4_preprocess_seqid_op() the stateid is obtained from nfsd4_lookup_stateid(), which holds a reference on the nfs4_stid (sc_count) but takes no reference on the stateowner. openlockstateid() merely casts that stid and likewise takes no reference. When nfsd4_cstate_assign_r...
CVE-2026-89689 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: nfsd: don't free session slots that are still in use nfsd4_sequence() can free the very slot it is currently processing. When the session shrinker has reduced se_target_maxslots below se_fchannel.maxreqs, the shrink path checks three conditions before calling free_session_slots(): 1. se_target_maxslots < maxreqs (shrink was advertised) 2. ...
CVE-2026-89702 New	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: size fh_verify server sockaddr slot by xpt_locallen The nfsd_fh_verify and nfsd_fh_verify_err tracepoints declare the server sockaddr slot sized by xpt_remotelen but fill it from xpt_local using xpt_locallen: TP_STRUCT__entry(... __sockaddr(server, rqstp->rq_xprt->xpt_remotelen) ...) TP_fa...
CVE-2026-89703 New	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: nfsd: set SC_STATUS_FREED in nfsd4_drop_revoked_stid for delegations nfsd4_drop_revoked_stid() handles FREE_STATEID for admin-revoked delegations but does not set SC_STATUS_FREED before releasing cl_lock. revoke_delegation() uses this flag to detect whether FREE_STATEID has already processed the delegation -- without it, the freed delegation is ...
CVE-2026-89708 New	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: RCU-protect cl_cb_session to fix use-after-free on session teardown After a DESTROY_SESSION the per-session teardown path can free a session while rpciod still holds an inflight callback rpc_task that dereferences clp->cl_cb_session. nfsd4_probe_callback_sync() flushes cl_callback_wq, but once nfsd4_run_cb_work() has called rpc_call_async...
CVE-2026-89712 New	9.8	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: NFSD: restart ssc_expire_umount walk after dropping nfsd_ssc_lock nfsd4_ssc_expire_umount() walks nn->nfsd_ssc_mount_list with list_for_each_entry_safe(ni, tmp, ...). For each expired entry it sets nsui_busy = true, drops nfsd_ssc_lock to run mntput() on the source vfsmount, then reacquires the lock to list_del + kfree the entry and continue it...
CVE-2026-81376 Newly scored	9.6	CRIT		0.006	microsoft:visual_studio_code	Incomplete comparison with missing factors in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-11746 Updated	9.4	CRIT		0.002	maven:com.linecorp.centraldogma:centraldogma-server fixed: 0.84.0	## Vulnerability `ZooKeeperReplicationConfig.secret()` silently substitutes the hard-coded constant `ch4n63m3` (leetspeak for "change me") whenever the operator omits `replication.secret`. The same secret is wired into both the **client-facing SASL context** and the **quorum/learner SASL contexts** of the embedded ZooKeeper. The constant is in OSS source on GitHub and is discoverable via code search in seconds...
CVE-2026-38056 New	9.4	CRIT		0.001		A local privilege escalation vulnerability exists in the iDirect iQ200 VSAT terminal running firmware 23.0.1.0. The iQ200 is a rackmount satellite modem deployed across oil and gas, maritime, defense, and remote infrastructure as the primary, and often sole communications link for offshore rigs, vessels, and remote sites. Important context: the device ships from the factory with a pre-configured low-privilege loca...
CVE-2026-61410 Newly scored	9.4	CRIT		0.013	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains a Missing Authorization vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution. This vulnerability is considered critical because it allows an attacker to execute commands remotely on a target system by sending a spe...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82466 Newly scored	9.4	CRIT		0.003		Rodauth before 2.46.0 contains an authentication bypass vulnerability in the webauthn_login route that allows logged-in users to authenticate as any other account. Attackers can exploit improper account resolution logic that falls back to session account identifiers instead of validating the credential binding to complete authentication as arbitrary users.
CVE-2026-86151 Newly scored	9.4	CRIT		0.02		A vulnerability was detected in Tenda CP3 27.5.57.101. The affected element is the function sub_2F77E8 of the file Apis/system.c of the component Network Configuration Management. Performing a manipulation results in os command injection. The attack may be initiated remotely.
CVE-2026-54072 New	9.3	CRIT		0.003		Authorizer is an open-source, self-hostable authentication and authorization server. Prior to version 2.2.1, the `authorize` endpoint accepts any `redirect_uri` without validating it against `AllowedOrigins`. When `response_type=token` or `response_type=id_token`, the server appends `access_token`, `id_token`, and `refresh_token` as query parameters and issues a 302 redirect to the attacker-supplied URL. An unaut...
CVE-2026-72709 New	9.3	CRIT		0.004		SPIP before version 4.4.18 contains a missing authorization vulnerability in sensitive actions under ecrire/action/ that allows unauthenticated attackers to invoke privileged actions by supplying only a valid CSRF nonce without any server-side permission check. Attackers can bypass template-level authorization guards through direct HTTP requests to invoke actions such as editer_auteur, enabling arbitrary account p...
CVE-2026-72710 New	9.3	CRIT		0.006		SPIP before 4.4.18 contains a mass assignment vulnerability in the editer_objet action that allows unauthenticated attackers to write arbitrary rows to any SQL table lacking a champs_editables allowlist by supplying an attacker-controlled arg parameter resolving to internal database tables. Attackers can insert a malicious row into the spip_jobs queue with a controlled PHP function and arguments, which is then dyn...
CVE-2026-80238 Newly scored	9.3	CRIT		0.001	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Execution with Unnecessary Privileges vulnerability. An unauthenticated attacker with local access could potentially exploit this vulnerability, leading to Protection mechanism bypass. This vulnerability is considered critical because a low-privileged operator with SSH access to the SCG host c...
CVE-2026-87984 New	9.3	CRIT		0.004		An arbitrary file write vulnerability in Mistral Vibe, introduced in version 1.3.4, allows an attacker to create or overwrite files outside the active workspace without user approval. Shell redirection destinations are omitted from permission checks, enabling otherwise allowlisted commands to write to arbitrary paths accessible to the Vibe process.
CVE-2026-89010 New	9.3	CRIT		0.029		WAVLINK WN535M1 and WN535M3 routers running firmware prior to M35M1_V250922 contain an unauthenticated OS command injection vulnerability that allows remote attackers to execute arbitrary commands as root by sending crafted filenames to the sync_server daemon on TCP port 13136. The daemon interpolates attacker-controlled filename input containing shell metacharacters into a shell command string via sprintf() and p...
CVE-2026-89249 New	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the YPTWallet plugin where user-supplied CryptoWallet values are base64-encoded but not HTML-escaped before storage in wallet_log.information. Administrators viewing pending withdrawal requests in pendingRequests.php execute the stored markup in their session, allowing attackers to perform adminis...
CVE-2026-89253 New	9.3	CRIT		0.003		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the user `donationLink` profile field. User::setDonationLink() (objects/user.php) stores the value and save() validates it only with filter_var(..., FILTER_VALIDATE_URL), which accepts strings such as http://evil.example/"onmouseover=alert(document.domain)//, while getDonationLink() applies o...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89254 New	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the CustomizeUser plugin where the field_name parameter is stored raw without sanitization. Administrators can inject malicious scripts via the add.json.php endpoint that execute when viewing extra info pages or profile forms that render the typeToHTML function.
CVE-2026-89255 New	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to HTML-encode PGP public keys echoed into a textarea element. An authenticated attacker can inject malicious JavaScript by submitting a crafted public key, which executes in an administrator's session when viewing the user's profile tab.
CVE-2026-89256 New	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the Bookmark plugin where chapter names are not encoded before being concatenated into public watch-page HTML. A video owner can inject malicious scripts via the bookmark name parameter, and every visitor of that video executes the payload in the AVideo origin.
CVE-2026-89258 New	9.3	CRIT		0.003		Hugo is a static site generator. In versions after v0.123.0 and before v0.165.0, symlinks in parent directories were not dropped during direct resource lookups, allowing path confinement to be bypassed. An attacker who can place — or who convinces a site author to place — a symlink inside a mounted directory (for example, in a locally vendored theme under themes/) can cause functions that perform direct lookups, s...
CVE-2026-89259 New	9.3	CRIT		0.004		Hugo is a static site generator. From v0.161.0, Hugo executes Node tools under Node's permission model, but TailwindCSS — included in the default security.exec.allow list — requires a highly permissive configuration (--allow-addons, --allow-child-process, --allow-worker). As a result, the restrictions intended by the fix for GHSA-x597-9fr4-5857 could still be bypassed, allowing a Node tool invoked during a build t...
CVE-2026-89448 New	9.3	CRIT		0.001		In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Force requesting ACS when tboot is enabled Currently the conditions of requesting ACS in detect_intel_iommu() don't include tboot, leading to a possible misconfiguration with ACS disabled (e.g. due to user opts) while iommu is later forced on by tboot_force_iommu(). Fix it by checking tboot in detect_intel_iommu().
CVE-2026-3869 New	9.2	CRIT		0.005		CWE-303 : Incorrect Implementation of Authentication Algorithm vulnerability exists that could cause loss of confidentiality, integrity and availability of the PLC provided an application project with a lower application level is running on the PLC.
CVE-2026-47839 New	9.2	CRIT		0.003		A vulnerability allows users authenticating through a federated OIDC provider to obtain the uaa.admin scope despite operators restricting that provider through externalGroupsWhitelist configuration. The issue occurs specifically when an OIDC identity provider uses groupMappingMode: AS_SCOPES with a wildcard externalGroupsWhitelist entry.
CVE-2026-54047 New	9.2	CRIT		0.002		Laci Synchroni is a decentralized mod and appearance sync server and plugin for Dalamud. Versions of the backend prior to 1.2.3 have an improper authentication vulnerability in the application's OAuth2 login flow. The application relies on client-side state by trusting the `UID` field inside the `Authentications` object of a user's local `config.json` file. By manually editing this local file on their PC prior to ...
CVE-2026-87983 New	9.2	CRIT		0.004		An arbitrary file read vulnerability in Mistral Vibe, introduced in version 2.6.0, allows an attacker to bypass workspace restrictions using quoted absolute paths in allowlisted shell commands. Improper handling of quotation marks during path validation enables files outside the active workspace to be read without user approval.
CVE-2026-89212 New	9.2	CRIT		0.003		A flaw resulting in XML external entity (XXE) was found in Akana API Platform in which references were improperly restricted during XML-to-JSON processing. The issue affects Akana versions 2026.1, 2025.1.1, and all versions before 2024.1.6 (including older unsupported versions of Akana) and has been fixed as a security patch in the latest release of supported versions.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89243 New	9.2	CRIT		0.004		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in UserGroups::setGroup_name() that fails to sanitize group_name input. Administrators with canAdminUserGroups permission can inject malicious HTML and JavaScript that executes in the browser when other administrators access the user manager interface.
CVE-2026-90456 New	9.2	CRIT		0.003		An example environment-configuration file for a bundled inventory-management component ships with a fixed, publicly-known administrative password. A deployment that copies this example file into active configuration without running the setup routine that regenerates credentials will expose that component's administrative interface to anyone aware of the default value.
CVE-2026-57162 Newly scored	9.1	CRIT		0.004	teluu:pjsip	PJSIP is a free and open source multimedia communication library written in C. Prior to commit a1b707c, a stack buffer overflow exists in the SRTP/SDS media transport when processing a=crypto attributes during SDP offer/answer (sdes_encode_sdp()) in transport_srtp_sdes.c). This affects applications with SRTP enabled (use_srtp optional or mandatory, using SDS keying). During media negotiation, the crypto attribute...
CVE-2026-57163 Newly scored	9.1	CRIT		0.002	teluu:pjsip	PJSIP is a free and open source multimedia communication library written in C. Prior to commit c4a151a, a stack buffer overflow exists in the GnuTLS TLS backend when parsing the Subject Alternative Name extension of a peer certificate (tls_cert_get_info()) in ssl_sock_gtls.c). Only GnuTLS builds are affected (--with-gnutls); OpenSSL and Apple SecureTransport/Network.framework builds are not affected. While extracti...
CVE-2026-73309 Newly scored	9.1	CRIT		0.005	xenforo:xenforo	XenForo before 2.3.13 contains an authentication bypass vulnerability in the OAuth2 token endpoint that allows unauthenticated attackers to obtain valid token pairs by submitting empty values for client_secret and code_verifier parameters. Attackers can exploit PHP truthy evaluation logic, which treats empty strings as false and skips client secret validation and PKCE code verifier validation, to exchange a valid ...
CVE-2026-73311 Newly scored	9.1	CRIT		0.004	xenforo:xenforo	XenForo before 2.3.13 contains an OAuth2 authorization code reuse vulnerability that allows attackers to obtain unauthorized token pairs by submitting a previously used authorization code. Attackers can exploit the failure to invalidate or mark authorization codes as consumed after initial token issuance to receive an independent token pair for the same user and scopes, bypassing the single-use guarantee of the OA...
CVE-2026-73312 Newly scored	9.1	CRIT		0.004	xenforo:xenforo	XenForo before 2.3.13 contains a refresh token replay vulnerability that allows attackers to reuse a refresh token multiple times by exploiting the failure to mark tokens as consumed when the parent access token has expired. Attackers can repeatedly submit the same refresh token to generate additional independent token pairs, achieving persistent unauthorized access for the token's full lifetime.
CVE-2026-75803 Newly scored	9.1	CRIT		0.002	openssl:openssl	Issue summary: ChaCha20-Poly1305 and AES-OCB decryption with an empty ciphertext can report success without verifying the supplied authentication tag when the operation is finalized by calling the EVP_Cipher() function. Impact summary: Applications calling EVP_Cipher() on an empty ciphertext and expecting the call to check the AEAD tag may accept forged messages. CWE: CWE-354 (Improper Validation of Integrity Ch...
CVE-2026-80945 New	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: crypto: iaa - unmap dst before software fallback on decompress On a hardware analytics error, decompress retries through the software fallback, which writes req->dst with the CPU while it is still mapped DMA_FROM_DEVICE. With SWIOTLB active the later dma_unmap_sg() copies the stale bounce buffer over req->dst, corrupting the result. Unmap befor...
CVE-2026-89532 New	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix pcl_for_each_segment for empty chunks When a parsed chunk list contains a chunk whose ch_segcount is zero, pcl_for_each_segment computes its inclusive upper bound as &chunk->ch_segments[ch_segcount - 1]. ch_segcount is u32, so the subtraction wraps to 0xFFFFFFFF and the bound lands far past the ch_segments flex array. The loop body ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89537 New	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Reject short RFC 4121 MIC tokens in gss_krb5_verify_mic_v2 gss_krb5_verify_mic_v2() reads the token ID at ptr[0..1], the flags byte at ptr[2], and padding at ptr[3..7], then passes ptr + GSS_KRB5_TOK_HDR_LEN and cksum_len to gss_krb5_mic_build_sg(). None of these accesses check read_token->len first. The minimum safe token size is GSS_K...
CVE-2026-89630 New	9.1	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: smb: client: restore the data_offset bound in is_valid_oplock_break() Commit 83bfbd0bb902 ("cifs: Remove the RFC1002 header from smb_hdr") changed the quantity this bound is measured against. It used to be srv->total_read minus the 4-byte RFC1002 preamble that total_read then included, so it was the SMB message length. The same commit stopped ...
CVE-2026-89631 New	9.1	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: smb: client: reject a tree connect response whose byte count is too small CIFSTCon() bounds its strlen() over the byte area with the server's ByteCount minus two, which for ByteCount 0 or 1 goes negative as an int and converts to a huge size_t. The later subtraction wraps the __u16 bytes_left, and that is what bounds cifs_strndup_from_utf16():...
CVE-2026-89634 New	9.1	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: smb: client: fix ALIGN() overflow in symlink_data() error context loop The check added by commit 7d9a7f1f96cd ("smb/client: fix possible infinite loop and oob read in symlink_data()") compared the post-ALIGN length against the remaining buffer, but ALIGN() itself can overflow: for ErrorDataLength near UINT32_MAX (e.g. 0xFFFFFFFF9), ALIGN(x, 8) wr...
CVE-2026-89649 New	9.1	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: ceph: bound xattr value length in __build_xattrs() __build_xattrs() decodes the MDS-supplied xattr blob one attribute at a time. For each attribute it reads a 32-bit name length, advances past the name bytes, reads a 32-bit value length, records the value pointer, and advances past the value bytes. The two length fields are read with ceph_decode...
CVE-2026-89650 New	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: bound num_export_targets array for mds info v2/v3 ceph_mdsmmap_decode() in fs/ceph/mdsmmap.c reads num_export_targets from each per-mds info record and advances the decode cursor by num_export_targets * sizeof(u32) without first checking that many bytes remain. The only upper-bound check that catches a runaway cursor (*p > info_end) is gated...
CVE-2026-89671 New	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs3 setacl by argp->mask nfsd3_proc_setacl() calls set_posix_acl() unconditionally for both ACL_TYPE_ACCESS and ACL_TYPE_DEFAULT, passing argp->acl_access and argp->acl_default verbatim. The NFSv3 ACL decoder only populates those pointers when the corresponding mask bit is set: nfs3svc_decode_setaclargs() if (args->mask & ...
CVE-2026-89672 New	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs2 setacl by argp->mask The NFSACL v2 SETACL path shares the decoder convention used by its v3 sibling: nfsaclsvc_decode_setaclargs() fills in argp->acl_access only when NFS_ACL is set in the request mask and argp->acl_default only when NFS_DFACL is set, leaving the other pointer NULL because the argument buffer is zeroed up to pc_a...
CVE-2026-89697 New	9.1	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: nfsd: add fh_want_write() for early-verified SETATTR in nfsd_proc_setattr() The BOTH_TIME_SET branch calls fh_verify() early so setattr_prepare() can inspect the dentry. This causes nfsd_setattr() to skip fh_want_write(), so notify_change() runs without a mount write reference. Add the missing fh_want_write() call after the early fh_verify().
CVE-2026-89713 New	9.1	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: NFSD: check truncate permission under inode lock nfsd_setattr() checks whether a size update needs NFSD_MAY_TRUNC before it takes inode_lock(). The comparison uses the file size sampled by that unlocked read, but the actual ATTR_SIZE update is applied later under inode_lock() by notify_change(). This leaves a TOCTOU window for append-only files...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69854 Newly scored	9.0	CRIT		0.006		Improper authentication in Spring Cloud Azure allows an unauthorized attacker to elevate privileges over a network.

Watchlist matches (other priorities)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84645 Newly scored	8.8	HIGH		0.007	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, objects of types marked as storing their configuration in independent top-level configuration files in Jenkins (such as the global configuration and jobs) can appear as nested field values in user-submitted `config.xml` documents and subsequently handle HTTP requests via Stapler, resulting in remote code execution.
CVE-2026-84648 Newly scored	8.8	HIGH		0.004	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, the system log viewer does not escape log record metadata (source, level, and timestamp) resulting in a stored cross-site scripting (XSS) vulnerability exploitable by attackers in control of agent processes.
CVE-2026-84650 Newly scored	8.8	HIGH		0.004	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, transient fields cannot be excluded from deserialization, allowing attackers able to submit configuration updates to specify the values of transient fields that will be deserialized, the impact depending on how those fields are used.
CVE-2026-72708 New	8.7	HIGH		0.003		SPIP before 4.4.18 contains an unauthenticated blind SQL injection vulnerability in the SQL escaping layer that allows unauthenticated attackers to inject arbitrary SQL by supplying a crafted annee parameter value matching a word character followed by an open parenthesis, which bypasses escaping for date-type columns across MySQL, SQLite, and PostgreSQL backends. Attackers can exploit the always-present sitemap.xml...
CVE-2026-81532 Newly scored	8.7	HIGH		0.003	mongodb:bi_connector_odbc_driver	A user able to submit SQL through an application using the MongoDB Connector for BI ODBC driver can supply a positioned-cursor statement whose cursor name exceeds the size of an internal fixed-length buffer. Because the name length is not bounded before the driver builds its diagnostic message, memory adjacent to that buffer is overwritten with user-supplied content. This can terminate the hosting application proc...
CVE-2026-78444 Newly scored	8.1	HIGH		0.005	microsoft:windows_10_1809, microsoft:windows_server_2019, microsoft:windows_server_2022, microsoft:windows_server_2025	Untrusted pointer dereference in Windows Failover Cluster allows an unauthorized attacker to execute code over a network.
CVE-2026-83997 Newly scored	8.1	HIGH		0.005	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-69727 Newly scored	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69773 Newly scored	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69352 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69476 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69489 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69583 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69589 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69593 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69787 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-70572 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70581 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72941 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72988 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72992 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72993 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72994 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72997 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73000 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73015 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73020 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77489 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Null pointer dereference in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77904 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-83988 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83990 Newly scored	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to elevate privileges locally.
CVE-2026-84000 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to execute code locally.
CVE-2026-89099 New	7.7	HIGH		0.002		A race condition in the document value layer of MongoDB Server can allow concurrent server threads to operate on the same internal memory without synchronization, leading to memory corruption. An authenticated user holding ordinary read-write privileges on a database may be able to trigger this condition over the normal client protocol, resulting in server termination and potential corruption of process memory wit...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-14457 Newly scored	7.5	HIGH		0.01	openssl:openssl	Issue summary: In a server or client configuration with RFC7250 Raw Public Keys (RPKs) enabled, and only the private key (with no associated certificate) configured locally, a NULL pointer dereference may occur when the remote peer solicits raw public keys and also sends the typically omitted "signature_algorithms_cert" TLS extension. Impact summary: The impact is limited to a possible Denial of Service as a resu...
CVE-2026-54874 Newly scored	7.5	HIGH		0.005	openssl:openssl	Issue summary: Receiving a DTLS record for a future epoch while a handshake is in progress causes OpenSSL to buffer far more memory than the record itself requires. Impact summary: A peer can use a small amount of network traffic to make an OpenSSL DTLS endpoint retain a disproportionately large amount of memory, which may lead to a Denial of Service. CWE: CWE-405: Asymmetric Resource Consumption (Amplification)...
CVE-2026-63072 Newly scored	7.5	HIGH		0.007	openssl:openssl	Issue summary: OpenSSL CMS decryption sizes the key-unwrap output buffer based on querying the unwrapped key size, but the AES-WRAP-PAD unwrap primitive can write and cleanse more bytes than that query reports, causing an 8-byte out-of-bounds heap write. Impact summary: An attacker who supplies a crafted CMS message can trigger a deterministic 8-byte out-of-bounds heap write when the victim decrypts it with CMS_d...
CVE-2026-63075 Newly scored	7.5	HIGH		0.005	openssl:openssl	Issue summary: When OpenSSL processes QUIC traffic from a peer that repeatedly sends ack-eliciting packets while not acknowledging ACK-only responses, the QUIC stack can retain ACK-only packet metadata for the lifetime of the connection. Impact summary: A remote peer that can complete a QUIC handshake can cause connection-scoped memory growth which may lead to Denial of Service through memory exhaustion, especial...
CVE-2026-63076 Newly scored	7.5	HIGH		0.013	openssl:openssl	Issue summary: OpenSSL CMP password based protection verification only checks whether the protectionAlg parameter was not NULL and not its ASN.1 type, before treating it as a PBMPParameter. A crafted message can contain a parameter of a different type, which is then dereferenced as an invalid pointer. Impact summary: A remote, unauthenticated attacker can crash an application acting as a CMP server that accepts PB...
CVE-2026-68497 New	7.5	HIGH		0.006		jackson-databind binds a JSON string to a javax.xml.datatype.Duration or javax.xml.datatype.XMLGregorianCalendar field by passing the raw string verbatim to DatatypeFactory.newDuration(value) or newXMLGregorianCalendar(value) in CoreXMLDeserializers.Std._deserialize. These deserializers are registered by default with no opt-in, so a plain ObjectMapper or JsonMapper with no polymorphic typing and no special configu...
CVE-2026-73017 Newly scored	7.5	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Graphics Kernel allows an authorized attacker to execute code locally.
CVE-2026-84652 Newly scored	7.3	HIGH		0.005	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, Jenkins does not rotate the session when a user is authenticated via the "remember me" cookie, allowing attackers able to serve content on the same site as Jenkins to set a known session cookie in the victim's browser, which after the victim authenticates via the "remember me" cookie, grants the attacker access to Jenkins as that user.
CVE-2026-20293 Newly scored	7.1	HIGH		0.001		A vulnerability in the Unified Extensible Firmware Interface (UEFI) Shell implementation of Cisco UCS Servers and UCS-based appliances could allow an authenticated attacker with valid credentials for a user account with the role of user or admin or an unauthenticated attacker with physical access to an affected device to bypass UEFI Secure Boot validation checks and execute unauthorized software. This vuln...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-68846 Newly scored	7.1	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.
CVE-2026-70573 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77905 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Management Instrumentation allows an authorized attacker to elevate privileges locally.
CVE-2026-78457 Newly scored	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2022, microsof	Use after free in Windows Security Health Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83999 Newly scored	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Improper link resolution before file access ('link following') in Windows Resilient File System (ReFS) Deduplication Service allows an authorized attacker to elevate privileges locally.
CVE-2026-50025 New	6.9	MEDI		0.002		Mousehole is a background service to update a seedbox IP for MAM and web app to manage it. Prior to version 0.4.05, Mousehole's HTTP/WebSocket management boundary is reachable without application-layer authentication or browser/LAN provenance checks. The service stores a MyAnonamouse (MAM) session cookie in state and reuses the same cookie-bearing serialization for persisted state, public API responses, and WebSoc...
CVE-2026-89261 New	6.9	MEDI		0.005		MoguBlog through 6.2 exposes Elasticsearch index management endpoints in the mogu_search service without authentication, allowing remote attackers to delete, recreate, or alter the blog search index. Attackers can invoke POST endpoints to wipe the entire search index, delete specific documents, or inject malicious index entries, causing search functionality to return incorrect or no results.
CVE-2026-89263 New	6.9	MEDI		0.003		MoguBlog through 6.2 fails to authenticate requests to the /web/comment/closeEmailNotification endpoint, allowing unauthenticated attackers to disable email notifications for arbitrary users. Remote callers can modify the startEmailNotification flag in Redis cache for any user identifier to suppress reply notifications without authorization.
CVE-2026-69415 Newly scored	6.8	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing authentication for critical function in Windows DHCP Server allows an authorized attacker to elevate privileges over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78451 Newly scored	6.8	MEDI		0.004	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Untrusted pointer dereference in Microsoft Windows SCSI Class System File allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-15439 New	6.5	MEDI		0.002		The GamiPress plugin for WordPress is vulnerable to authenticated (Subscriber+) SQL Injection via the 'q' parameter of the wpForo integration AJAX selector (action gamipress_wpforo_get_posts) in versions up to, and including, 7.9.7. The value is passed only through \$wpdb->esc_like() and interpolated directly into a single-quoted LIKE clause with no %s placeholder. Because esc_like() runs after WordPress core magic...
CVE-2026-54248 New	6.5	MEDI		0.002		Doco-CD is a GitOps continuous delivery tool that automatically deploys and updates Docker Compose projects/services and Swarm stacks. Prior to version 0.90.1, a trust-boundary flaw in OCI artifact verification allowed artifact-provided deployment config to influence the policy used to verify that same artifact. When global OCI signature verification was enabled via `OCI_TRUST_POLICY` (enabled: true), an attacke...
CVE-2026-78453 Newly scored	6.5	MEDI		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information over a network.
CVE-2026-84651 Newly scored	6.3	MEDI		0.002	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, the REST API and CLI endpoints for updating agent configuration do not prevent a submitted configuration from overwriting a different agent by specifying that agent's name in the submitted XML document, allowing attackers with Agent/Configure permission on one agent to take over a different agent, gaining control of its configuration and obtaining access to it...
CVE-2026-81533 Newly scored	6.0	MEDI		0.002	mongodb:bi_connector_odbc_driver	An application using the MongoDB BI Connector ODBC Driver may encounter a memory-safety issue when a submitted SQL statement contains an unusually long run of digits following a LIMIT clause. The issue occurs only on connections where the driver's optional prefetch setting is enabled, and stems from the driver copying the digit sequence into a fixed-size internal buffer without checking its length. A user able to ...
CVE-2026-63074 Newly scored	5.9	MEDI		0.005	openssl:openssl	Issue summary: The OpenSSL Certificate Management Protocol (CMP) caches additional certificates (extraCerts) sent in a CMP message, but never expunges them (for instance if they are invalid). If a server reuses an OSSL_CMP_CTX frequently, this cache of extraCerts may grow unboundedly, and a malicious client may flood a CMP server with requests driving this growth. Impact summary: Users utilizing a CMP server tha...
CVE-2026-78454 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows CD-ROM Driver allows an authorized attacker to disclose information locally.
CVE-2026-86224 Newly scored	5.5	MEDI		0.003		A vulnerability was determined in SourceCodester Class and Exam Timetabling System 1.0. Affected is the function mysqli_query of the file /admin/modal_add_product.php. Executing a manipulation of the argument fname can lead to sql injection. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-62088 New	5.3	MEDI		0.002		Insertion of Sensitive Information Into Sent Data vulnerability in 10up ElasticPress allows Retrieve Embedded Sensitive Data. This issue affects ElasticPress: from n/a through 5.3.4.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78446 Newly scored	5.3	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Distributed File System (DFS) allows an authorized attacker to deny service over a network.
CVE-2026-89298 New	4.9	MEDI		0.002		A flaw was found in the Dynamic Client Registration service of Keycloak, an open-source identity and access management solution. The issue occurs when a user with the view-clients role accesses the client registration endpoint to retrieve client details. Due to a failure to mask sensitive information, the service returns the client's confidential secret in cleartext. This could allow a read-only administrator to o...
CVE-2026-78452 Newly scored	4.6	MEDI		0.005	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Out-of-bounds read in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78547 New	4.4	MEDI		0.002		Out-of-bounds write vulnerability in Citrix Citrix Workspace app for Windows. This issue affects Citrix Workspace app for Windows: before 2603.11 Current Release (CR), before 2507.1 LTSR CU3, and before LTSR 2607.
CVE-2026-78455 Newly scored	4.3	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Xbox allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-84646 Newly scored	4.3	MEDI		0.003	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, user objects can appear as nested field values in other deserialized XML objects, allowing attackers with Overall/Read permission to create user objects by submitting crafted XML.
CVE-2026-54513 Updated				0.009	maven:com.fasterxml.jackson.core:jackson-databind, maven:tools.jackson.core:jackson-databind fixed: 2.18.8, 2.21.4, 3.1.4	## Summary `BasicPolymorphicTypeValidator.Builder.allowIfSubTypesArray()` allowlists any array type based only on `clazz.isArray()`, without validating the array's component (element) type against the configured allowlist. A PTV built with `allowIfSubTypesArray()` plus an explicit concrete-type allowlist therefore still permits `EvilType[]` even though `EvilType` is not allowlisted. When Jackson deserializes the...
CVE-2026-59971 Updated		CRIT		0.004	pip:mysql-mcp-server fixed: 0.4.2	## Summary In SSE/HTTP transport mode, `mysql_mcp_server` constructs `SseServerTransport` without passing `security_settings`. As a result, the MCP Python SDK's DNS-rebinding protection (Origin/Host header validation) is disabled; the Starlette application has no CORS or TrustedHost middleware; and the service binds to `0.0.0.0` by default with no authentication on any route. **Trigger condition:** `MCP_TRANSPOR...

P3/P4 items (952) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.